

UNIVERSIDAD DE LAS PALMAS DE GRAN CANARIA

Escuela de Ingeniería Informática

Práctica 10:
MECANISMOS DE DEFENSA EN NUESTRO
ENTORNO DOMÉSTICO

Asignatura: Seguridad de la Información

Curso: 4º de Grado en Ingeniería Informática

Autor:

Nicolás Rey Alonso

`nicolas.rey101@alu.ulpgc.es`

Fecha: Abril 2026

Índice general

1. Introducción	3
1.1. Objetivos de la práctica	3
1.2. Fundamentos teóricos	3
1.2.1. Enunciado:	4
1.2.2. Introducción a CVE, CVSS y las principales bases de datos	4
1.3. Enunciado de la práctica	5
2. Análisis del sistema doméstico	6
2.1. Configuración General de Equipo	6
2.1.1. Especificaciones del Sistema Operativo	6
2.1.2. Hardware y Componentes	6
2.2. Políticas de Seguridad y Mantenimiento	7
2.2.1. Gestión de Cuentas de Usuario	7
2.2.2. Política de Contraseñas	7
2.2.3. Política de Copias de Seguridad (Backup)	7
2.3. Política y Gestión de Actualizaciones (Patch Management)	8
2.3.1. Requisitos y Proceso de Actualización	8
2.3.2. Evidencia Gráfica	8
3. Análisis de la conexión a Internet	9
3.1. Descripción General del Router (WAN)	9
3.2. Configuración de Red Inalámbrica (Wi-Fi / WLAN)	11
4. Protección contra el malware	12

4.1. Estado actual de la protección contra malware	12
--	----

Capítulo 1

Introducción

1.1. Objetivos de la práctica

El objetivo fundamental de esta práctica es la obtenención de información y familiarización con las amenazas a la seguridad digital.

1.2. Fundamentos teóricos

Para la realización de esta práctica, se aplican diversos conceptos teóricos clave de la ciberseguridad y la seguridad de la información, entre los que destacan:

- **Conocimiento de los CVE/CWE:** CVE (Common Vulnerabilities and Exposures) es un sistema de identificación de vulnerabilidades conocido a nivel mundial, mientras que CWE (Common Weakness Enumeration) clasifica las debilidades de software. Familiarizarse con estas bases de datos es esencial para entender las amenazas actuales y cómo mitigarlas.
- **Phishing:** Técnica de ingeniería social utilizada para engañar a los usuarios y obtener información confidencial, como contraseñas o datos bancarios, a través de correos electrónicos, mensajes o sitios web falsos.
- **Malware:** Software malicioso diseñado para dañar, explotar o comprometer sistemas informáticos. Puede incluir virus, troyanos, ransomware, spyware, entre otros.
- **Ransomware:** Tipo de malware que cifra los archivos de la víctima y exige un rescate para restaurar el acceso a los datos. Es una amenaza creciente para empresas y particulares.

- **Botnets:** Redes de dispositivos comprometidos (ordenadores zombies) controlados por un atacante para realizar actividades maliciosas, como ataques DDoS, envío de spam o minería de criptomonedas.
- **SQL Injection:** Vulnerabilidad que permite a un atacante ejecutar código SQL malicioso en una base de datos a través de una aplicación web, lo que puede resultar en la exposición o manipulación de datos sensibles.
- **Cross-Site Scripting (XSS):** Vulnerabilidad que permite a un atacante inyectar scripts maliciosos en páginas web vistas por otros usuarios, lo que puede llevar al robo de cookies, secuest

1.2.1. Enunciado:

1. Introducción a CVE, CVSS y las principales bases de datos

1.2.2. Introducción a CVE, CVSS y las principales bases de datos

El estándar CVE (Common Vulnerabilities and Exposures) consiste en un sistema de identificación y catalogación de vulnerabilidades de software y hardware. El objetivo de esta norma es suministrar un marco común para que las organizaciones, desarrolladores y profesionales de la seguridad puedan discutir, reportar y gestionar estas vulnerabilidades de manera uniforme. La gestión de CVE es coordinada principalmente por MITRE (Management of Information Technology Research and Evaluation), que establece los estándares y el marco operativo para la asignación de estos identificadores.

Por otra parte, las CNA (CVE Numbering Authorities) son organizaciones autorizadas para asignar identificadores CVE a vulnerabilidades específicas. Estas autoridades pueden ser fabricantes de software, investigadores de seguridad o entidades académicas, y su función es garantizar que cada vulnerabilidad se registre de manera precisa y rastreable. La asignación de un CVE a una vulnerabilidad implica un proceso riguroso de verificación y documentación para asegurar la integridad del sistema. Una vez que una vulnerabilidad ha sido identificada y registrada con un CVE, su impacto se cuantifica utilizando el sistema CVSS (Common Vulnerability Scoring System). CVSS es un método estandarizado que asigna una puntuación numérica (de 0.0 a 10.0) que refleja la severidad y la explotabilidad de la vulnerabilidad.

En cuanto a las principales bases de datos, existen diferencias clave: CVE.org es el registro central donde se publican y gestionan los identificadores CVE. La NVD (National Vulnerability Database), mantenida por el NIST (Instituto Nacional de Estándares y Tecnología), es una base de datos que recopila datos sobre vulnerabilidades, incluyendo puntuaciones CVSS asociadas a múltiples identificadores CVEs. Finalmente, FIRST.org (Forum of Incident Response and

Security Teams) es un foro más amplio centrado en la colaboración comunitaria, las mejores prácticas y el desarrollo de estándares de respuesta a incidentes de seguridad, aunque no es una base de datos directa de vulnerabilidades como la NVD.

1.3. Enunciado de la práctica

Esta práctica consiste en la realización de un informe basado en una selección de noticias de prensa digital, posteriores al 1 de enero de 2025, relacionadas con una serie de amenazas informáticas.

Las amenazas objeto de esta actividad serán:

1. Phishing, estafas a través de la red
2. Malware difundido en redes sociales
3. Ataques de ransomware contra corporaciones y gobiernos
4. Botnets, ordenadores zombies
5. Malware en dispositivos móviles
6. Inyección de código SQL
7. Cross-Site Scripting (XSS)

Capítulo 2

Análisis del sistema doméstico

En este apartado se decidió analizar el sistema que uso laboralmente/educativamente, el cuál es un portatil MacBook air con chip M2.

2.1. Configuración General de Equipo

2.1.1. Especificaciones del Sistema Operativo

Fabricante y Versión del Sistema Operativo:

- Fabricante: Apple
- Versión del SO: macOS Tahoe 26.3.1

2.1.2. Hardware y Componentes

Detalle de la Configuración del Equipo:

- CPU: Apple M2
- RAM instalada: 8 GB LPDDR5
- Discos Duros/SSD (Capacidad y Tipo): 512 GB SSD en dos modulos de 256 GB cada uno.
- Otros componentes relevantes (ej. Tarjeta gráfica, etc.): GPU integrada Apple M2 con 10 núcleos, neural engine de 16 núcleos, cámara FaceTime HD, 2 microfonos.

2.2. Políticas de Seguridad y Mantenimiento

2.2.1. Gestión de Cuentas de Usuario

Número total de cuentas de usuario: 1

Cuentas con privilegios de Administrador (o equivalente): 1

◇ Lista de usuarios administradores: NicolasReyAlonso

2.2.2. Política de Contraseñas

Descripción de la Política de Contraseñas:

- Requisitos mínimos (longitud, complejidad): Apple te permite configurar una contraseña de cualquier tipo, y puntúa la calidad de la contraseña, pero no impone requisitos mínimos. En mi caso, tengo una contraseña de 14 caracteres mínimo con mayúsculas, minúsculas, números y símbolos.
- Frecuencia de cambio: No hay una frecuencia de cambio obligatoria, pero apple desaconseja el cambio frecuente ya que supuestamente lleva a los usuarios a utilizar contraseñas simples. Este dato es interesante, ya que va en contra de la creencia común de que cambiar las contraseñas frecuentemente mejora la seguridad. En mi caso, no tengo una frecuencia de cambio establecida, pero suelo cambiarla cada 6 meses aproximadamente, ya que independientemente de la frecuencia, el acceso principal se realiza mediante la autenticación biométrica.
- Uso de autenticación multifactor (MFA): Sí, tengo configurada la autenticación multifactor utilizando la aplicación de autenticación de Apple (Apple Authenticator) y también tengo configurada la autenticación biométrica (Touch ID) para acceder al sistema.
- Restricciones implementadas (bloqueo de cuentas inactivas, etc.): _____

2.2.3. Política de Copias de Seguridad (Backup)

Estrategia de Copias de Seguridad:

- Frecuencia de las copias: Cada 3 meses, o en caso de realizar cambios significativos en el sistema, en los datos o en proyectos que no se puedan recuperar a través de github.
- Tipo de copias (completas, incrementales, etc.): Copias completas utilizando Time Machine de Apple.

- Almacenamiento (local, nube, etc.): Solo local, utilizando Time Machine de Apple con un disco duro externo.
- Procedimiento de recuperación en caso de fallo: En caso de fallo, se puede restaurar el sistema utilizando las copias de seguridad realizadas con Time Machine. Esto se puede hacer a través del modo de recuperación de macOS, seleccionando la opción de restaurar desde una copia de seguridad de Time Machine y siguiendo las instrucciones en pantalla para seleccionar la copia de seguridad deseada.

2.3. Política y Gestión de Actualizaciones (Patch Management)

2.3.1. Requisitos y Proceso de Actualización

Fecha Límite de Mantenimiento y Seguridad:

- Fuente de información utilizada para la fecha límite: Apple software updater.
- Frecuencia con la que se revisan estas fechas: Cada 3 meses, o en caso de recibir una notificación de Apple sobre una actualización crítica.

Descripción Detallada de la Política de Actualizaciones:

- Tipo de actualizaciones permitidas (seguridad, funcionalidad, etc.): Ninguna automática. solo permito la descarga de actualizaciones pero no la instalación automática.
- Frecuencia de instalación: Tras realizar la copia de seguridad
- Método de instalación (automático/manual): automático a través de Apple Software Updater y de brew para las aplicaciones instaladas a través de este gestor de paquetes.
- Procedimiento de prueba antes de la implementación: _____

2.3.2. Evidencia Gráfica

Captura de Pantalla del Nivel de Actualización del Sistema Operativo:

Figura 2.1: Captura de pantalla del nivel de actualización y estado de seguridad del Sistema Operativo.

Capítulo 3

Análisis de la conexión a Internet

3.1. Descripción General del Router (WAN)

Esta sección contiene los detalles básicos y las configuraciones físicas de la conexión a Internet.

Direccionamiento IP

1. Dirección IP Pública del Router: Obtenida a través de la configuración avanzada del router.: _____

88.24.71.160

2. Direcciones Privadas (LAN): ¿Tiene direcciones privadas? Si es afirmativo, especificar la dirección IP privada principal o rango.: _____

Sí, tiene direcciones privadas. La dirección IP privada principal es 192.168.1.1 y su rango es del 33 al 199

Filtrado de Tráfico (Firewall)

3. ¿El router tiene filtrado de conexiones entrantes? Respuesta: [Sí/No]: _____

Sí

Nota: En caso afirmativo (y si se especificaron direcciones privadas), responder lo siguiente:

4. ¿Hay alguna configuración especial de conexiones entrantes? Si es afirmativo, deta-

llar las asignaciones específicas (ej.: Puerto Forwarding XYZ).: _____

Si, tengo un port forwarding configurado para el puerto 3000, ya que tenía un servidor node express montado.

Credenciales y Acceso al Router

5. Origen de la Contraseña del Router: ¿La contraseña asignada es por el instalador o es propia?: _____

Asignada por el instalador. Ya que es un entorno doméstico no la he cambiado por la falta de conocimientos de mis familiares.

3.2. Configuración de Red Inalámbrica (Wi-Fi / WLAN)

Detalle sobre la configuración del acceso inalámbrico.

Seguridad y Funcionalidades Wi-Fi

1. Nivel de Seguridad: Indicar el nivel utilizado: [WEP / WPA / WPA2 / WPA3]:

WPA2

2. Medidas Adicionales Implementadas: Marcar o describir cualquier medida especial (Filtrado de MAC, No anuncio del SSID, desactivación del DHCP/WPS, empleo de 802.X, etc.): _____

Credenciales Inalámbricas

3. Origen de la Contraseña WiFi: ¿La contraseña asignada es por el instalador o es propia?: _____

Asignada por el instalador. Ya que es un entorno doméstico no la he cambiado por la falta de conocimientos de mis familiares.

Anexos y Evidencia Visual

Adjuntar captura(s) de pantalla de las opciones básicas de configuración del router. Se requiere evidencia visual para validar la información proporcionada en el documento.

Capítulo 4

Protección contra el malware

4.1. Estado actual de la protección contra malware

Antes de la realización de esta práctica, el equipo (basado en el sistema operativo macOS) contaba exclusivamente con las soluciones de seguridad nativas de Apple, sin disponer de software antimalware de terceros instalado. Para la realización de este apartado se instaló por recomendación de los usuarios del foro reddit y de la ia gemini. Fue necesaria la instalación de este software ya que el sistema operativo de Apple no cuenta con un software antimalware que permita realizar escaneos completos del sistema de forma manual, sino que se basa en mecanismos de protección integrados y automáticos. Estos mecanismos incluyen:

- **XProtect:** Un sistema de detección de malware basado en firmas que se actualiza automáticamente a través de las actualizaciones de macOS. XProtect escanea los archivos descargados y las aplicaciones en busca de malware conocido, bloqueando su ejecución si se detecta una amenaza.
- **Gatekeeper:** Un sistema de seguridad que impide la ejecución de aplicaciones no firmadas o que no provengan de desarrolladores identificados por Apple. Gatekeeper verifica la firma digital de las aplicaciones antes de permitir su ejecución, lo que ayuda a prevenir la instalación de software malicioso.
- **Herramienta de eliminación de malware (MRT):** Una herramienta que se ejecuta automáticamente en segundo plano para eliminar malware conocido que pueda haber infectado el sistema. MRT se actualiza regularmente a través de las actualizaciones de macOS para garantizar la protección contra las amenazas más recientes.
- **Sanboxing:** macOS utiliza técnicas de sandboxing para aislar las aplicaciones y limitar su acceso a los recursos del sistema. Esto ayuda a prevenir que el malware pueda afectar

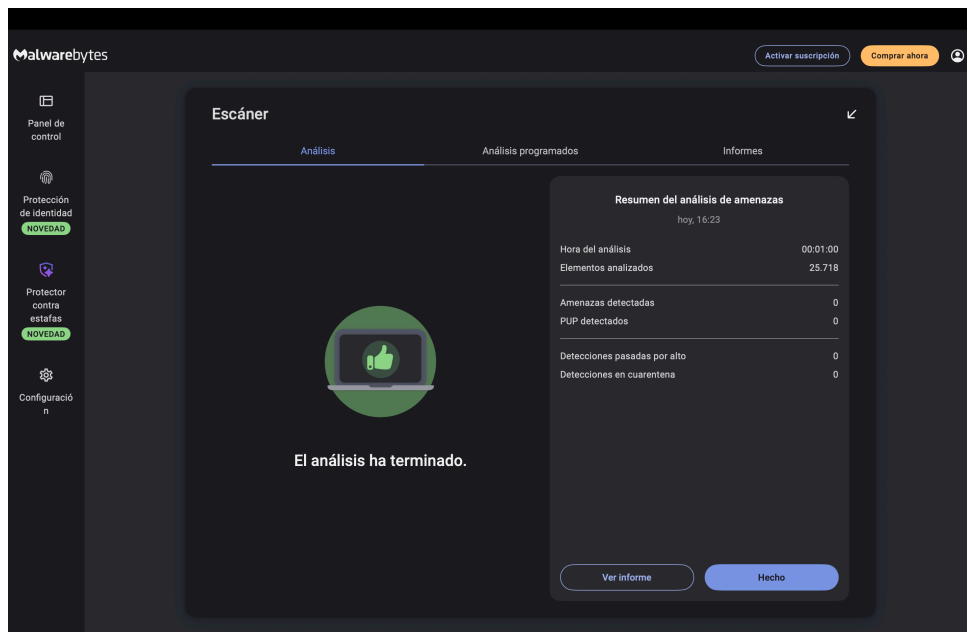


Figura 4.1: Resultado de la comprobación malware 1.

otras partes del sistema o acceder a datos sensibles manteniendo dichos ficheros como solo lectura.

Personalmente, considero que estas medidas de seguridad integradas en macOS son efectivas para proteger contra muchas amenazas comunes, pero no garantizan una protección completa contra todas las formas de malware. Sin embargo, soy reacio a la instalación de software antimalware de terceros, ya que pueden consumir recursos e incluso soluciones populares como Avast, McAfee etc. han sido objeto de controversias por prácticas de recopilación de datos. A parte, considero poco prudente dar a un software de terceros (o de fabrica) permiso de lectura y escritura sobre los ficheros de mi sistema, ya que en el peor de los casos podría comprometer la seguridad personal mía (por ejemplo, china con sus políticas ciudadanas de “puntos”). Es, además, de consenso general que la mejor forma de protegerse contra el malware es mantener el sistema operativo y las aplicaciones actualizadas, evitar descargar software de fuentes no confiables y practicar buenos hábitos de seguridad en línea. Asimismo, el equipo que se ha analizado en esta práctica se utiliza principalmente para tareas de desarrollo y pruebas, lo que reduce el riesgo de infección por malware en comparación con un entorno de uso general.

Por otra parte, es importante destacar que una forma efectiva de comprobar la seguridad del equipo, sobre todo cuando se trabaja en el entorno IT es comprobar el rendimiento del equipo, el consumo de recursos y el trafico de red, ya que en ocasiones existen softwares que aunque no se consideren malware; actuan como un malware, se instalan sin el consentimiento del usuario y monitorizan el uso del equipo de la misma forma que un malware (por ejemplo, windows copilot).

El equipo que se ha analizado, cumple con casi todas las recomendaciones impartidas en

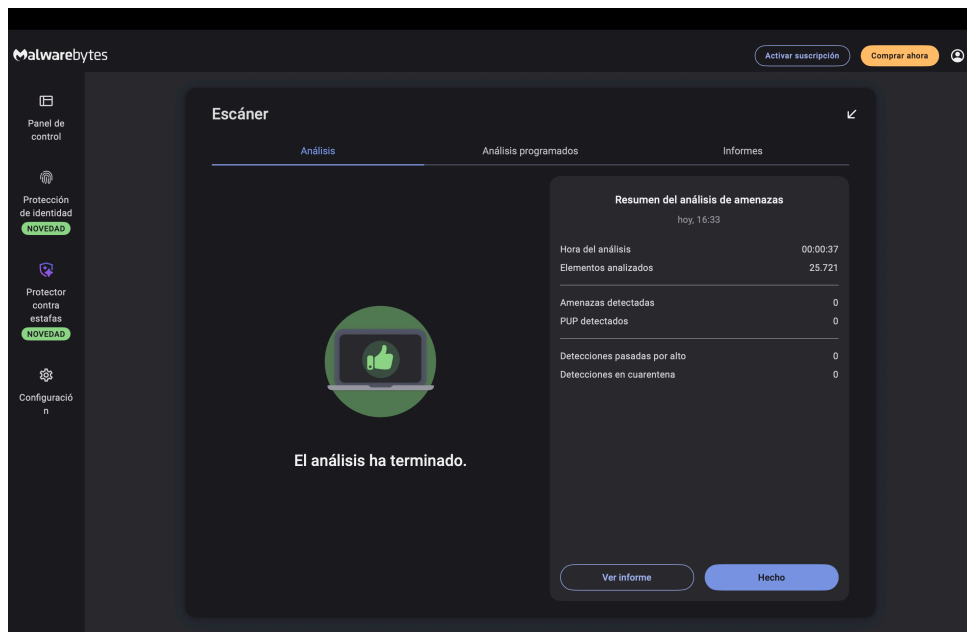


Figura 4.2: Resultado de la comprobación malware 2.

el manual de seguridad de la información de la unidad 1 a la 4: Utiliza un sistema operativo actualizado, con las últimas actualizaciones de seguridad, no tiene software de terceros instalado, no se han detectado signos de infección por malware, utiliza en el wifi WPA2, el disco esta cifrado, se utilizan contraseñas seguras y autenticación multifactor, se realizan copias de seguridad periódicas, etc. Sin embargo, es importante destacar que la seguridad de una red es tan fuerte como su eslabón más débil, y en este caso de estudio, el simple hecho de que el router wifi disponga de boton wps, y que el equipo se conecte a este router, es un punto de vulnerabilidad importante, ya que el protocolo wps es vulnerable a ataques de fuerza bruta, lo que podría permitir a un atacante obtener acceso a la red wifi y comprometer la seguridad del equipo y de la red en general. Por lo tanto, aunque el equipo en sí mismo esté bien protegido, la seguridad de la red wifi a la que está conectado es un aspecto crítico que debe ser abordado para garantizar una protección completa contra el malware y otras amenazas.

Capítulo 5

Buenas prácticas de seguridad

Recomendación 1: Al utilizar *wearables* (pulseras o relojes inteligentes), se debe configurar los mecanismos de protección de la propia aplicación que gestiona el dispositivo y revisar las opciones de privacidad de la red social con la que se sincroniza, ya que estos sensores capturan datos biométricos altamente sensibles sobre la salud.

Ficha número: 18

Recomendación 2: En servicios de mensajería instantánea, se recomienda hacer uso de la opción de “chat privado” o “secreto” para evitar que personas ajenas a la conversación puedan espiarla, además de asegurar que el intercambio de mensajes esté siempre cifrado.

Ficha número: 10

Recomendación 3: Al utilizar navegadores, se debe instalar un “verificador de páginas web” (generalmente proporcionado por los principales antivirus) para obtener una capa adicional de seguridad que valide la reputación de los sitios antes de interactuar con ellos.

Ficha número: 8